



von Bülow Consulting
STRATEGISCHER KI-
PARTNER

PRAXIS-GUIDE
NR. 01 / 2026

STAND 22. JUNI 2026 · NACH DIGITAL OMNIBUS VOM 16.06.2026

DSGVO und EU AI Act. *Praxis-Guide* für den Mittelstand.

*Was Sie wirklich tun müssen. Nicht mehr
und nicht weniger.*

FORMAT

PDF · 24 Seiten

LESEZEIT

30 Minuten

AUTOR

Kai von Bülow

STAND

Juni 2026

Was Sie auf den nächsten **22 Seiten** erhalten.

01	Die Lage im Sommer 2026	S. 03
02	Risiko-Klassifizierung Ihrer Anwendungen	S. 06
03	Fünf Compliance-Checklisten	S. 09
04	Vorlagen-Bibliothek	S. 16
05	Sieben Fallstricke aus der Praxis	S. 19
06	30-Tage-Plan zum Stichtag	S. 21
07	Wann externe Unterstützung sinnvoll ist	S. 23
B	Bonus: Selbst-Audit-Karte	S. 24

Quellen-Apparat. Jede Faktenaussage in diesem Guide ist mit einer Quelle belegt. Die Quellenliste finden Sie auf der letzten Seite. Stand der Faktenlage: 22. Juni 2026.

Die *echten Stichtage* für den Mittelstand.

Der EU AI Act ist seit August 2024 in Kraft. Die Pflichten greifen gestaffelt. Durch den Digital Omnibus vom 16. Juni 2026 wurden mehrere Termine verschoben. Das ist die aktuelle Lage für den Mittelstand.

DATUM	WAS GREIFT	MITTELSTANDS-RELEVANZ
02. Feb 2025 AKTIV	Art. 4 KI-Kompetenz. Nachweispflicht über qualifizierten Umgang Ihrer Mitarbeitenden mit KI-Tools.	TRIFFT JEDEN Jedes Unternehmen mit ChatGPT-Login.
02. Feb 2025 AKTIV	Art. 5 Verbote. Social Scoring, Emotion-Recognition am Arbeitsplatz, untargeted Scraping.	TRIFFT SELTEN Achtung bei HR-Tools mit Stimmungsanalyse.
02. Aug 2026 AKUT	Art. 50 Transparenzpflichten. Chatbot, Voicebot und KI-generierte Inhalte müssen gekennzeichnet werden.	TRIFFT VIELE Wer KI-Chatbots auf der Website hat: jetzt prüfen.
02. Aug 2026 AKUT	Bußgeld-Befugnisse für GPAI-Verstöße. Aufsichtsbehörden können Strafen verhängen.	MITTELBAR Wirkt über Vertragsanpassungen Ihrer KI-Anbieter.
02. Dez 2026 KURZ DANACH	Watermarking-Pflicht für AI-generated Content. Maschinenlesbare Kennzeichnung wird Pflicht.	MITTELBAR Wird über Ihre KI-Tools bereitgestellt.
02. Dez 2027 ECHTE DEADLINE	High-Risk Annex III. KI im Recruiting, Kredit-Scoring, kritische Infrastruktur. Conformity Assessment Pflicht.	TRIFFT VIELE Wer KI im HR-Bereich einsetzt: jetzt vorbereiten.
Laufend PARALLEL	DSGVO. Bei personenbezogenen Daten gilt sie unverändert. AI Act ist zusätzlich, nicht ersetzend.	TRIFFT JEDEN Datenschutz-Folgenabschätzung ersetzt kein Conformity Assessment.

AKTUELL

Stand der formalen Rechtslage. Der Digital Omnibus wurde am 16.06.2026 vom EU-Parlament mit 423 zu 57 Stimmen angenommen. Die formale Annahme im Rat wird für den 29.06.2026 erwartet. Die Verschiebungen sind also faktisch sicher, aber bis dahin formal noch nicht abgeschlossen.

Was es kostet, *wenn man falsch liegt.*

VERBOTENE PRAKTIKEN

**35 Mio.
€**

oder 7 % Welt-Jahresumsatz

Art. 99 Abs. 3

SONSTIGE PFLICHT- VERSTÖSSE

**15 Mio.
€**

oder 3 % Welt-Jahresumsatz

Art. 99 Abs. 4

FALSCHER BEHÖRDEN-INFO

**7,5
Mio. €**

oder 1 % Welt-Jahresumsatz

Art. 99 Abs. 5

Es gilt jeweils die höhere Summe. Für KMU und Start-ups: die niedrigere. Die Bußgeld-Befugnisse für GPAI-Verstöße gelten ab 02.08.2026, die für die übrigen Pflichten ab Inkrafttreten der jeweiligen Vorschrift.

Deutsche Aufsicht: KI-MIG vom 11. Juni 2026

Der Bundestag hat am 11.06.2026 das KI-Marktüberwachungs- und Innovationsförderungs-Gesetz (KI-MIG) beschlossen. Die zuständige Aufsichts-Behörde ist die Bundesnetzagentur. Sektoral arbeiten BaFin (Finanz-KI), BfArM (Medizinprodukte), BSI (Cyber-Security) und der BfDI plus die Landes-Datenschutzbehörden mit. Die Bundesrats-Zustimmung steht aus Stand 22.06.2026 noch aus.

GRAUE ZONE

Es gibt aktuell keinen verbindlichen Konfliktlösungs-Mechanismus zwischen Bundesnetzagentur und den 16 Landes-Datenschutzbehörden. Bei High-Risk-Anwendungen kann das bedeuten: zwei voneinander unabhängige Audits durch unterschiedliche Behörden. Wer hier früh Klarheit schafft, ist im Vorteil.

UNSICHER BEI DER EINORDNUNG?

30 Min Klarheits-Call *zu Ihrem Setup.*

Ohne Sales-Pitch. Wenn der Call genug ist, war es das.

Termin sichern →

Was sich durch den *Digital Omnibus* geändert hat.

Am 16. Juni 2026 hat das EU-Parlament mit 423 zu 57 Stimmen Änderungen verabschiedet. Hier die Kurzfassung für den Mittelstand.

BEREICH	VORHER	JETZT
High-Risk Annex III	02. Aug 2026	02. Dez 2027 (verschoben)
High-Risk Annex I	02. Aug 2027	02. Aug 2028 (verschoben)
Watermarking Pflicht	02. Aug 2026	02. Dez 2026 (4 Mon. Karenz)
Nationale Regulatory Sandboxes	02. Aug 2026	02. Aug 2027 (verschoben)
GPAL-Pflichten (Anbieter)	02. Aug 2026	02. Aug 2026 (bleibt)
Art. 50 Grund-Transparenzpflichten	02. Aug 2026	02. Aug 2026 (bleibt)
Neue Verbote AI-CSAM / Nudifier	nicht existent	neu, Stichtag 02. Dez 2026

Was das praktisch bedeutet

- Mehr Zeit für High-Risk-Vorbereitung. Aber 02. Dez 2027 ist die echte Deadline, nicht das Verschwinden der Pflicht.
- Die Grund-Transparenzpflichten für Chatbots und Voicebots bleiben am 02.08.2026 scharf. Wer KI-Kommunikation einsetzt, muss vorbereitet sein.
- Watermarking läuft 4 Monate später an. Das ist Aufgabe Ihres KI-Anbieters, nicht Ihre eigene.
- Bei Bestandskunden mit hochkomplexen KI-Systemen entlastet die Verschiebung erheblich. Bei Neuprojekten ändert sie wenig.

Vier Risiko-Klassen. *Wo steht Ihre KI?*

Der EU AI Act kennt vier Klassen. Drei davon haben Pflichten. Die richtige Einstufung entscheidet darüber, was Sie tun müssen.

KLASSE 1 Verboten · Unacceptable Risk

Komplett untersagt seit 02.02.2025. Höchste Bußgelder im AI Act.

Verboten: Mitarbeiter-Emotion-Tracking im Sales-Call, Social Scoring durch HR-Software, Predictive Policing, untargeted Face-Scraping aus Webcams.

KLASSE 2 Hoch · High-Risk

Anwendbar ab 02.12.2027 (Annex III) bzw. 02.08.2028 (Annex I). Strenge Pflichten: Conformity Assessment, technische Dokumentation, menschliche Aufsicht, Audit-Trail, Anmeldung in EU-Datenbank.

High-Risk: KI-Resume-Screening, Performance-Bewertung durch KI, Kreditwürdigkeitsprüfung, Versicherungs-Underwriting Leben/Kranken, biometrische Identifikation.

KLASSE 3 Begrenzt · Limited Risk

Anwendbar ab 02.08.2026. Hauptpflicht ist Transparenz: der Nutzer muss wissen, dass er mit einer KI interagiert oder dass ein Inhalt KI-generiert ist.

Begrenzt: Customer-Service-Chatbot, KI-Voicebot Inbound-Sales, KI-generierte Marketing-Bilder, Deepfake-Stimme im Werbespot.

KLASSE 4 Minimal · Minimal Risk

Keine spezifischen Pflichten aus dem AI Act. Aber Art. 4 KI-Kompetenz und die DSGVO gelten weiter.

Minimal: ChatGPT/Claude für Marketing-Copy ohne Personenbezug, KI-Spam-Filter, KI-Rechtschreibprüfung, KI-Übersetzung interner Dokumente, KI-Codevervollständigung.

15 Mittelstands-Use-Cases *richtig einsortiert.*

USE-CASE	KLASSE	ERSTE PFLICHT
ChatGPT-Login für Marketing-Texte	Minimal	Art. 4 KI-Kompetenz nachweisen
Website-Chatbot Support	Begrenzt	Kennzeichnung als KI, 02.08.2026
KI-Voicebot Inbound-Sales	Begrenzt	Akustische Offenlegung, 02.08.2026
KI-Resume-Screening	Hoch	Conformity Assessment ab 02.12.2027
Performance-Bewertung durch KI	Hoch	Conformity Assessment ab 02.12.2027
Mitarbeiter-Emotion-Analyse Sales-Calls	Verboten	Sofort stoppen, schon verboten
Kreditwürdigkeitsprüfung mit KI	Hoch	Conformity Assessment ab 02.12.2027
KI-Bilder im Marketing	Begrenzt	Kennzeichnung, 02.08.2026
KI-Übersetzung interner E-Mails	Minimal	DSGVO bei pers. Daten
n8n-Workflow mit Claude-Klassifizierung	Minimal	AVV-Vertrag mit Claude-Anbieter
KI-basierte Beleg-Klassifizierung	Minimal	DSGVO, AVV mit Anbieter
Deepfake-Stimme in eigenem Marketing	Begrenzt	Deutliche Kennzeichnung
KI für Versicherungs-Underwriting	Hoch	Conformity Assessment ab 02.12.2027
KI-Predictive-Maintenance Produktion	Minimal	Art. 4 KI-Kompetenz
Social-Scoring-Tool Personalabteilung	Verboten	Sofort stoppen

Hinweis: die Tabelle ist eine Orientierungshilfe. Die finale Einstufung hängt vom konkreten Setup, Datenbestand und Einsatz-Kontext ab. Bei High-Risk-Verdacht: vor der Einführung prüfen lassen.

IHRE ANWENDUNG NICHT DABEI?

Wir klassifizieren *in 30 Minuten.*

Per Calendly direkt einen Slot buchen. Keine Vorbereitung nötig.

Slot buchen →

Checkliste 1: *Website-Chatbot.*

Für jeden öffentlich zugänglichen Chatbot mit Kundenkontakt. Stichtag der Transparenzpflicht: 02.08.2026.

1. **KI-Kennzeichnung im Chat-Fenster.** Der Hinweis «Sie chatten mit einer KI» muss vor der ersten Antwort sichtbar sein, nicht im Footer versteckt.
2. **Ausstieg zum Menschen.** Klare Option, einen menschlichen Mitarbeitenden zu erreichen.
3. **Datenschutz-Hinweis.** Welche Daten werden verarbeitet, wo gespeichert, wie lange.
4. **Auftragsverarbeitungsvertrag (AVV)** mit dem Chatbot-Anbieter.
5. **Logs sicher gespeichert** und nach DSGVO-Frist gelöscht.
6. **Keine sensiblen Daten verarbeiten** (Gesundheit, Sexualleben, politische Meinung) ohne explizite Einwilligung.
7. **Mitarbeitenden-Schulung** zur Bedienung und Eskalation.
8. **Halbjährliche Überprüfung** der Antworten auf Diskriminierung oder Falschauskunft.
9. **Verantwortliche Person benannt** (in der Regel Datenschutz-Beauftragte).
10. **Art. 4 KI-Kompetenz dokumentiert** für alle Mitarbeitenden, die den Chatbot betreuen.

Häufige Verstöße im Mittelstand

- Kennzeichnung erst im Footer der Website, nicht im Chat selbst.
- Kein AVV mit dem Chatbot-Anbieter (besonders bei OpenAI-Direktanbindungen).
- Chat-Logs unbefristet gespeichert, ohne Lösch-Konzept.

Checkliste 2: *KI-Voicebot.*

Für Inbound- und Outbound-Telefonie mit KI-Stimme. Art. 50 verlangt akustische Offenlegung. Plus DSGVO und Telekommunikations-Telemedienschutz-Gesetz (TTDSG).

1. **Akustische Offenlegung am Gesprächsbeginn.** Der Anrufer muss vor dem ersten Sprechen hören: «Sie sprechen mit einer KI».
2. **Im Outbound: Einwilligung zur KI-Ansprache** dokumentiert. Werbeanrufe brauchen Einwilligung nach UWG, Voicebot zusätzlich nach AI Act.
3. **Datenschutz-Folgenabschätzung** (Art. 35 DSGVO) für jeden Voicebot mit Kundendaten.
4. **Aufzeichnung der Anrufe** nur mit Einwilligung beider Seiten.
5. **Zwei-Sekunden-Regel:** der Anrufer muss das KI-System innerhalb von zwei Sekunden als solches erkennen können.
6. **Eskalation zum Menschen** bei Bitte des Anrufers verfügbar.
7. **Anbieter-AVV** für den Voicebot-Service (z.B. ElevenLabs, Vapi, Retell).
8. **Verarbeitung in EU-Rechenzentren** oder dokumentierte Standardvertragsklauseln bei US-Anbietern.
9. **Lösch-Konzept für Transkripte** nach maximal 90 Tagen.
10. **Kein KI-Voicebot für sensible Themen** (Krankheitsanfragen, Schuldnerberatung) ohne menschliche Übergabe.

PRAXIS-TIPP

Die meisten Mittelstands-Voicebots scheitern an Punkt 5. Wenn der Anrufer erst nach 15 Sekunden merkt, dass er mit einer KI spricht, ist die Compliance verletzt. Lassen Sie die Begrüßung von 5 unabhängigen Personen testen.

VOICEBOT SCHON IM EINSATZ?

30 Min Voicebot-Audit. *Sofortbefund.*

Wir hören uns Ihren Bot an und sagen, was fehlt.

[Audit starten →](#)

Checkliste 3: *KI im Bewerbermanagement.*

High-Risk-Anwendung ab 02.12.2027. Aber DSGVO Art. 22 (automatisierte Entscheidung) gilt schon heute. Diese Liste deckt beides ab.

1. **Keine vollautomatisierte Ablehnung.** DSGVO Art. 22 verlangt menschliche Letzt-Entscheidung bei rechtlich wirkenden Auswirkungen.
2. **Bewerber-Information vor Bewerbung.** KI-Einsatz in der Stellenanzeige offenlegen.
3. **Diskriminierungs-Test** der KI-Auswahl alle 6 Monate (AGG-Konformität).
4. **Erklärbarkeit der Entscheidung.** Bei Ablehnung muss erläuterbar sein, welche Kriterien den Ausschlag gaben.
5. **Datenschutz-Folgenabschätzung** (DSGVO Art. 35) liegt vor.
6. **Conformity Assessment vorbereiten** bis 02.12.2027 (für High-Risk Annex III Nr. 4).
7. **Technische Dokumentation** des KI-Systems vorhalten (für High-Risk).
8. **Menschliche Aufsicht dokumentiert.** Wer prüft die KI-Vorschläge? Wann? Wie?
9. **Audit-Trail aller Entscheidungen** mit Begründung.
10. **Einspruchs-Mechanismus** für abgelehnte Bewerber.
11. **Anbieter-AVV** für das HR-Tool plus dokumentierte Standardvertragsklauseln bei US-Anbietern.
12. **Anmeldung in EU-Datenbank** wird ab 02.12.2027 verlangt (High-Risk-Register).

Wer heute schon KI-Resume-Screening einsetzt, fängt nicht erst 2027 an. Die DSGVO-Pflichten sind heute scharf, das Conformity Assessment bereitet sich vor.

KI IM RECRUITING IM EINSATZ?

Conformity-Roadmap *bis Dez 2027.*

30 Min Erstgespräch zur Standortbestimmung Ihrer HR-KI.

[Termin buchen →](#)

Checkliste 4: *KI-Dokumenten-Klassifizierung.*

Verarbeitung von Rechnungen, Belegen, Verträgen, Bewerbungen mit OCR und LLM-Klassifizierung. Meist Minimal-Risk im AI Act, aber DSGVO-relevant.

1. **Auftragsverarbeitungsvertrag** mit dem Anbieter (Lexware, DATEV, Klassifizierungs-API, etc.).
2. **Datenschutz-Hinweis** auf der eigenen Website angepasst.
3. **Aufbewahrungsfristen geklärt.** Dokumente mit personenbezogenen Daten unterliegen DSGVO-Löschpflichten.
4. **EU-Rechenzentrum** oder dokumentierte Standardvertragsklauseln.
5. **Verschlüsselung in Transit und at Rest** dokumentiert.
6. **Zugriffsrechte minimal halten.** Nur wer es braucht, sieht die Dokumente.
7. **Audit-Log der Verarbeitung** (welches Dokument wurde wann von welcher KI klassifiziert).
8. **Menschliche Überprüfung** bei Entscheidungen mit Außenwirkung (z.B. Rechnungs-Freigabe).
9. **Art. 4 KI-Kompetenz** für Mitarbeitende, die mit der KI arbeiten.

Checkliste 5: *LLM-Workflows in n8n, Make oder Zapier.*

1. **AVV mit dem LLM-Anbieter** (Anthropic, OpenAI, Google) plus mit dem Workflow-Anbieter.
2. **Dokumentation des Datenflusses.** Welche Daten gehen wohin? Wo werden sie verarbeitet?
3. **Keine personenbezogenen Daten ungeschützt durchschicken.** Maskierung bei nicht-DSGVO-konformen Anbietern.
4. **Workflow-Logs DSGVO-konform.** Lösch-Konzept dokumentiert.
5. **Output-Validierung.** LLM-Antworten werden geprüft, bevor sie an Endkunden gehen.
6. **Halluzinations-Sicherung.** Strukturierte Outputs mit Schema-Validierung statt freier Text.
7. **Rollen-Definition.** Wer ändert den Workflow? Wer überwacht ihn?
8. **Art. 4 KI-Kompetenz** für alle Workflow-Betreuer.

Vorlage 1: *Transparenz-Hinweis im Chatbot.*

Direkt zum Einbau im Chat-Fenster, sichtbar vor der ersten Antwort.

VORLAGE CHAT-ERÖFFNUNG

Hallo und willkommen. Sie chatten hier mit einer KI-Assistenz von [Firmenname]. Ich kann Ihnen bei Fragen zu unseren Leistungen, Öffnungszeiten und Preisen helfen. Bei komplexeren Anliegen leite ich Sie an einen Mitarbeitenden weiter.

Ihre Eingaben werden verarbeitet, um Ihre Anfrage zu beantworten. Details zur Datenverarbeitung finden Sie in unserer [Datenschutzerklärung](#).

Wie kann ich Ihnen helfen?

Vorlage 2: *Voicebot-Begrüßung.*

VORLAGE INBOUND-VOICEBOT

«Guten Tag, hier ist die KI-Assistenz von [Firmenname]. Ich kann Ihnen bei Terminvereinbarungen und ersten Fragen weiterhelfen. Möchten Sie lieber mit einem Mitarbeitenden sprechen? Dann sagen Sie einfach »Mitarbeiter«. Wie kann ich Ihnen helfen?»

Vorlage 3: *AVV-Klausel für KI-Tools.*

Ergänzung für bestehende Auftragsverarbeitungsverträge bei Nutzung von LLM-Diensten.

AVV-ZUSATZ KI-VERARBEITUNG

Zusatzvereinbarung zu Künstlicher Intelligenz

Der Auftragsverarbeiter erklärt, dass die im Rahmen der Leistungserbringung eingesetzten KI-Modelle:

1. nicht mit den vom Verantwortlichen bereitgestellten personenbezogenen Daten weitertrainiert werden,
2. ausschließlich für die Bearbeitung des konkreten Auftrags verwendet werden,
3. in Rechenzentren in der EU oder unter dokumentierten Standardvertragsklauseln verarbeitet werden,
4. einen Audit-Trail über jede Verarbeitung führen, der für 6 Monate vorgehalten wird,
5. vom Auftragsverarbeiter regelmäßig auf Diskriminierungs- und Halluzinations-Risiken überprüft werden,
6. im Falle einer Risikoklassifizierung als High-Risk i.S.d. AI Act den Anforderungen aus Kapitel III des AI Act entsprechen.

Der Auftragsverarbeiter informiert den Verantwortlichen unverzüglich, wenn sich die KI-Modelle oder deren Risikoklassifizierung wesentlich ändern.

Vorlage 4: *Interne KI-Richtlinie.*

Eine Seite zum Anpassen und in den Onboarding-Prozess integrieren.

KI-NUTZUNGS-RICHTLINIE [FIRMENNAME]

- 1. Erlaubte Tools.** Mitarbeitende dürfen folgende KI-Tools für berufliche Zwecke nutzen: [Liste pflegen]. Andere Tools sind vor Nutzung mit der IT-Leitung abzustimmen.
- 2. Verbotene Inhalte.** In KI-Tools dürfen keine eingegeben werden: Personaldaten, Kundendaten mit Identifikation, Finanzkennzahlen vor Veröffentlichung, technische Details aus Verträgen mit Vertraulichkeitspflicht, Gesundheitsdaten.
- 3. Kennzeichnung.** Texte, die zu 50 % oder mehr von KI generiert sind, werden intern als «KI-Entwurf» gekennzeichnet, bevor sie weiterverwendet werden.
- 4. Verantwortung.** Der Mitarbeitende trägt die Verantwortung für die Korrektheit jedes Outputs. KI-Halluzinationen sind kein Entschuldigungsgrund.
- 5. Schulung.** Jeder Mitarbeitende, der KI nutzt, absolviert die interne KI-Kompetenz-Schulung (Art. 4 EU AI Act) und bestätigt dies schriftlich.
- 6. Datenschutz.** Bei Verdacht auf einen Datenschutzvorfall wird unverzüglich die Datenschutz-Beauftragte informiert.
- 7. Audit.** Die Geschäftsleitung kann die Nutzung von KI-Tools auditieren, ohne die personenbezogenen Eingaben einzusehen.

«Vorlagen sind ein Startpunkt. Das echte Risiko liegt im *konkreten Setup* Ihres Unternehmens.»

KAI VON BÜLOW

VORLAGE PASST NICHT GANZ?

Wir passen sie an. *In 30 Minuten.*

Bringen Sie Ihre eigene KI-Anwendung mit. Wir liefern den passenden Text.

Slot sichern →

Sieben Fallstricke, *die teuer werden.*

Die folgenden Konstellationen tauchen bei Mittelstands-Audits regelmäßig auf. Die meisten lassen sich in einer Woche beheben, wenn sie früh erkannt werden.

01 ChatGPT-Privatlogin mit Firmen-Mailadresse

Mitarbeitende loggen sich mit ihrer Firmen-Mail in private ChatGPT-Accounts ein. Ergebnis: keine AVV, keine Kontrolle über die Eingaben, kein DSGVO-konformer Datenfluss. Lösung: zentrale Team-Accounts oder API-Anbindung über IT.

02 Voicebot ohne akustische KI-Offenlegung

Der Voicebot meldet sich als «Frau Meier vom Service». Der Anrufer merkt nach 30 Sekunden, dass es eine KI ist. Das ist Art. 50 Abs. 1 verletzt. Lösung: Begrüßung anpassen, Test mit 5 unabhängigen Personen.

03 KI-Resume-Screening ohne DSGVO-Hinweis

In der Stellenanzeige fehlt der Hinweis, dass KI eingesetzt wird. Bewerber haben keine Möglichkeit, sich darauf einzustellen oder Einspruch einzulegen. DSGVO Art. 13/14 verletzt. Lösung: Stellenanzeigen-Template aktualisieren.

04 Keine Art. 4 KI-Kompetenz-Dokumentation

Das Unternehmen nutzt seit Jahren KI-Tools, hat aber nie eine interne Schulung dazu durchgeführt. Bei einem Audit kann die Pflicht aus Art. 4 nicht nachgewiesen werden. Lösung: einmalige Basis-Schulung plus jährliche Auffrischung dokumentieren.

05 n8n-Workflow mit US-Anbindung ohne SCC

Der n8n-Workflow schickt Kundendaten an einen US-LLM-Anbieter, ohne Standard-vertragsklauseln (SCC) abzuschließen. Schrems-II-Konformität nicht gewährleistet. Lösung: SCC abschließen, dokumentieren, oder Anbieter wechseln.

06 Chat-Logs unbefristet gespeichert

Customer-Service-Chats werden in der CRM-Datenbank ohne Lösch-Konzept gespeichert. Bei einer DSGVO-Auskunftsanfrage muss alles offengelegt werden. Lösung: 90-Tage-Lösch-Regel implementieren oder dokumentierte Aufbewahrungs-Begründung.

07 Stimmungs-Analyse bei Vertriebsmitarbeitenden

Ein Sales-Tool analysiert die Stimmung der eigenen Vertriebsmitarbeitenden während Kundenanrufen. Das ist nach Art. 5 Abs. 1 lit. f seit Februar 2025 verboten. Bußgeld bis 35 Mio. €. Lösung: sofort abschalten, nur Kunden-Sentiment analysieren.

LESSON LEARNED

Bei allen sieben Fallstricken liegt der Fehler nicht in der KI-Technologie. Er liegt im organisatorischen Setup. Wer ein Audit besteht, hat nicht weniger KI, sondern bessere Dokumentation.

EINER DER SIEBEN FÄLLE TRIFFT AUF SIE ZU?

30 Min, dann wissen Sie *was zu tun ist*.

Konkrete Antworten statt allgemeine Hinweise.

Termin sichern →

Ihr *30-Tage-Plan* bis zum Stichtag 02.08.2026.

Vier Wochen, klare Aufgaben, pro Tag eine konkrete Verantwortung. Für Geschäftsleitung, IT-Leitung und Datenschutz-Beauftragte.

WOCHE 1 · INVENTUR

- › Bestandsaufnahme aller KI-Tools im Unternehmen (Liste mit Verantwortlichen und Use-Cases)
- › Risiko-Klassifizierung jeder Anwendung nach Kapitel 02 dieses Guides
- › AVV-Status pro Tool prüfen, fehlende AVV anfordern
- › Verantwortliche Person pro KI-Tool benennen und dokumentieren

WOCHE 2 · QUICK-WINS

- › Chatbot-Kennzeichnungen prüfen und anpassen, wenn nötig
- › Voicebot-Begrüßungen testen und überarbeiten
- › Datenschutz-Hinweise auf der Website aktualisieren
- › Stellenanzeigen-Templates um KI-Hinweis ergänzen
- › Interne KI-Richtlinie an alle Mitarbeitenden schicken

WOCHE 3 · DOKUMENTATION

- › Datenschutz-Folgenabschätzungen pro Use-Case erstellen oder aktualisieren
- › Audit-Trails einrichten, wo sie noch fehlen
- › Lösch-Konzepte für Chat-Logs, Transkripte, Workflow-Outputs definieren
- › KI-Kompetenz-Schulungen planen und Termine festlegen

WOCHE 4 · TEST & ÜBERGABE

- › Praxis-Test: 5 unabhängige Personen prüfen Chatbot und Voicebot auf Erkennbarkeit
- › Interne Audit-Simulation
- › Geschäftsleitungs-Briefing über Status und Restrisiken
- › Vorbereitung der KI-Kompetenz-Schulungen für Q3
- › Roadmap bis Dezember 2027 (High-Risk-Vorbereitung) skizzieren

ALLEIN ZU VIEL?

Wir machen den 30-Tage-Plan *mit Ihnen.*

Klares Tagesgeschäft. Klare Verantwortlichkeiten. Übergabe an Ihr Team.

[Plan besprechen →](#)

Wann externe Unterstützung *sinnvoll ist.*

Was Sie intern lösen können

- Kennzeichnung von Chatbots und Voicebots
- Aktualisierung der Datenschutz-Hinweise
- Einführung einer internen KI-Richtlinie
- AVV-Verträge prüfen und einholen
- Art. 4 KI-Kompetenz-Schulungen mit Standard-Curriculum
- Lösch-Konzepte und Audit-Trails einrichten

Wann externe Hilfe sinnvoll ist

- Bei einer geplanten High-Risk-Anwendung (Recruiting-KI, Kredit-Scoring): Conformity-Assessment-Vorbereitung braucht spezialisierte Expertise.
- Bei der Architektur neuer KI-Workflows: Compliance «by Design» ist günstiger als nachträgliche Anpassung.
- Bei einer geplanten Übergabe der KI-Systeme an das eigene Team: Übergabe-Konzept inkl. Schulung und Dokumentation.
- Bei einem konkreten Audit oder DSGVO-Verfahren: schnelle, präzise Antwort auf Behörden-Anfragen.

EHRliche FAUSTREGEL

Die meisten Mittelstands-Themen sind intern lösbar. Externe Hilfe bringt Mehrwert dort, wo Spezialwissen einmalig gebraucht wird und das eigene Team danach selbst weitermacht. Wer das Gegenteil hört, sollte sich einen anderen Berater suchen.

Was wir machen

von Bülow Consulting bietet drei Festpreis-Pakete für KI- und Compliance-Vorhaben. Jedes Paket beinhaltet eine vollständige Übergabe an Ihr Team. Nach 12 Monaten sind Sie unabhängig.

Spike

4.500 €

3 Tage Klarheits-Audit oder
Konzept. Sie wissen danach,
wo Sie stehen und was
kommt.

Sprint

12.000 €

2 bis 3 Wochen
Implementierung eines klar
definierten Use-Cases inkl.
Übergabe.

Mandat

28.500 €

8 Wochen vollständige
Pipeline mit Schulung,
Dokumentation und
Übergabe.

SIE WISSEN NICHT, WELCHES PAKET?

30 Min Calendly, *klare Empfehlung.*

Kein Sales-Druck. Nur Klarheit, was zu Ihrer Lage passt.

Termin sichern →

Selbst-Audit: *12 Ja-Nein-Fragen.*

Eine A4-Seite zum Ausdrucken oder als digitale Vorlage für die nächste Geschäftsleitungs-Sitzung. Jedes «Nein» ist ein Handlungsbedarf.

01	Haben wir eine Liste aller KI-Tools, die wir einsetzen?	Ja	Nein
02	Haben wir AVV-Verträge mit allen KI-Anbietern?	Ja	Nein
03	Sind alle KI-Chatbots auf unserer Website gekennzeichnet?	Ja	Nein
04	Hat unser Voicebot eine akustische KI-Offenlegung?	Ja	Nein
05	Haben wir eine interne KI-Nutzungs-Richtlinie?	Ja	Nein
06	Sind alle Mitarbeitenden in Art. 4 KI-Kompetenz geschult?	Ja	Nein
07	Setzen wir KI im Recruiting ein? Wenn ja: ist DSGVO Art. 22 berücksichtigt?	Ja	Nein
08	Haben wir Lösch-Konzepte für Chat-Logs und Transkripte?	Ja	Nein
09	Wissen wir bei jeder KI, in welchem Rechenzentrum sie verarbeitet wird?	Ja	Nein
10	Haben wir keine verbotenen KI-Praktiken (Emotion-Tracking bei MA, Social Scoring)?	Ja	Nein
11	Haben wir für jede KI eine verantwortliche Person benannt?	Ja	Nein
12	Haben wir einen 30-Tage-Plan bis zum 02.08.2026?	Ja	Nein

0-3x Nein: Sie sind gut aufgestellt. Bestätigen Sie es mit einem leichten Audit.

4-7x Nein: Handlungsbedarf in einzelnen Bereichen. Der 30-Tage-Plan aus Kapitel 06 schließt die meisten Lücken.

8x oder mehr Nein: Strukturierter Aufbau nötig. Holen Sie sich Unterstützung, bevor der erste Audit kommt.

VIER ODER MEHR MAL NEIN ANGEKREUZT?

30 Min Calendly. *Wir besprechen die Lücken.*

Praxis-Antworten zu Ihren konkreten Antworten. Ohne Sales-Skript.

Termin sichern →



von Bülow Consulting
STRATEGISCHER KI-PARTNER

«*Der EU AI Act wird im Mittelstand entweder ignoriert oder massiv überinterpretiert. **Beides ist teuer.** Dieser Guide gibt Ihnen die Mitte: das, was Sie wirklich tun müssen. Nicht mehr und nicht weniger.*»

KAI VON BÜLOW · GRÜNDER VON BÜLOW CONSULTING

NÄCHSTER SCHRITT

30 Minuten *Erstgespräch.*

Klären Sie in einem unverbindlichen Call, wo Sie stehen und was die nächsten drei Schritte sind. Direkt im Kalender buchen.

Termin im Kalender wählen →

calendly.com/vonbuelow-consulting/30min

WEB vonbuelow-consulting.de
E-MAIL kai@vonbuelow-consulting.de
LINKEDIN linkedin.com/in/kai-von-buelow

Stand 22. Juni 2026. Dieser Guide ersetzt keine Rechtsberatung. Quellen-Apparat verfügbar auf Anfrage. © 2026 von Bülow Consulting, Kai von Bülow.